

Endpoint Investigator

Coleta, correlaciona e interpreta processos, permissões e serviços de um endpoint Linux — separando o que foi observado do que é hipótese

Gabriel Galazzi · João Pedro Sardou

Prof. Rodolfo Avelino · Insper · 06/10/2026

```
$ python3 -m investigator \
    --dataset training/correlation
```

```
[ALTA] F-001 (C1+C4)
backup-agent.service
  → User=root
  → PID 2417
  → /opt/backup/backup.sh (0777)
  → gravável por não-root
```

CONCLUSÃO: RISCO
confiança alta · 4 fontes

Evidência isolada não é incidente



Raciocínio simplista

~~serviço root = vulnerável~~

~~curl em execução = malware~~

~~conexão externa = C2~~

~~arquivo 0777 = ataque~~

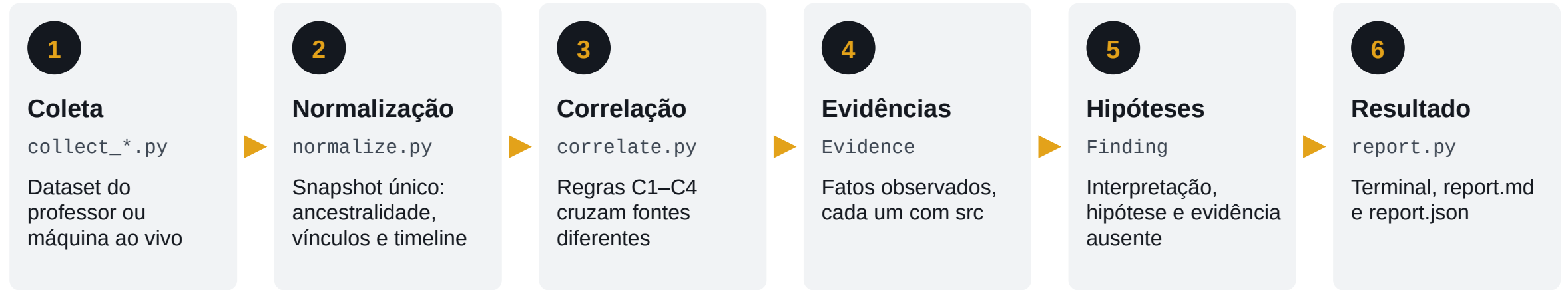


Nossa estratégia

- Risco = identidade privilegiada + recurso usado + quem pode modificá-lo
- RISCO só com ≥ 2 tipos de fonte independentes
- Toda evidência cita sua origem (src)
- Faltou dado? A resposta é INCONCLUSIVO

Escopo processos · permissões · serviços + logs, sockets e cron (live) · snapshot sob demanda, sem agente

Arquitetura: um Snapshot, um pipeline



Metade 1 · coleta e normalização (Galazzi)

Metade 2 · análise e relatório (Sardou)



Duas entradas, um contrato

Dataset e coleta ao vivo viram o mesmo Snapshot; a análise não sabe a origem.



Proveniência em todo fato

Cada fato carrega src — `processes.csv:5`, `/proc/2417/status` — e toda conclusão aponta para ele.



Lacunas declaradas

O que não pôde ser coletado vai para `Snapshot.gaps` e aparece no relatório.

Processos, permissões e serviços



Processos

- PID, PPID e usuário; UID real × efetivo no live
- Cadeia de ancestralidade com a identidade de cada elo
- Script real por trás do interpretador (bash → backup.sh)
- Usuário → root sem sudo/su/pkexec é sinal; root → usuário é normal

`/proc/PID/status · stat · cmdline`



Permissões

- nonroot_writable: o+w, grupo não-root, dono não-root ou diretório-pai gravável
- SUID/SGID fora dos diretórios padrão
- Coleta por contexto: só caminhos usados por serviços, processos e cron
- Symlink e sticky bit (/tmp) não geram falso positivo

`os.lstat · permissions.csv`



Serviços

- User, ExecStart, MainPID e unit file
- Vínculo processo ↔ serviço em ordem de força: cgroup > MainPID > ExecStart > script > ancestral > nome
- O método fica registrado: o vínculo é auditável
- Serviço root, sozinho, nunca vira achado

`systemctl show · services.txt`

Quatro correlações entre fontes

C1

Serviço + processo + permissão

Serviço root → processo que o executa → cada caminho referenciado → quem pode alterá-lo, inclusive via diretório-pai.

→ **RISCO** · INCONCLUSIVO · **CONTEXTO_OK**

C2

Processo + PPID + usuário

Ancestralidade com identidade: usuário → root sem sudo/su/pkexec; root rodando de /tmp ou /home; filho de serviço root com destino externo.

→ **RISCO** · INCONCLUSIVO · **CONTEXTO_OK**

C3

Arquivo + usuário + uso

SUID/SGID fora do padrão (e se algo o usa); gravável por todos sem vínculo privilegiado; /etc/shadow e /etc/sudoers.

→ **CONFIG_INADEQUADA** · INCONCLUSIVO · **CONTEXTO_OK**

C4

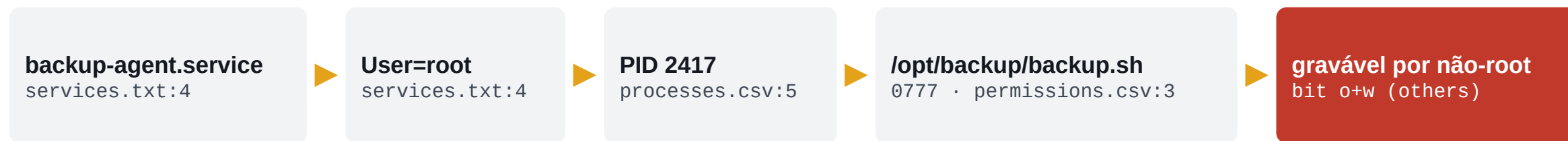
Processo + serviço + log

Ordena login não-root, mtime e (re)início do serviço, enriquecendo C1. Aponta log de parada com o processo ainda vivo.

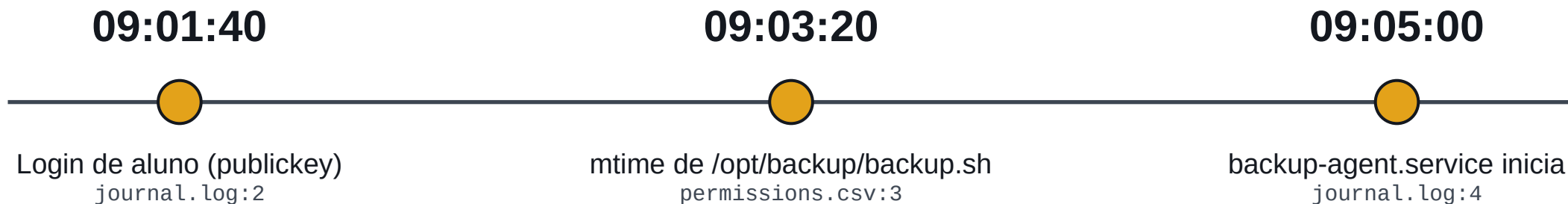
→ INCONCLUSIVO · enriquece C1

Da cadeia ao achado: C1 + C4

C1 · relação de privilégio cenário tampered_after_login



C4 · reconstrução temporal



RISCO · confiança alta (4 fontes). A ordem login → modificação → início é descrita como coincidência temporal, não autoria. Isso NÃO prova exploração.

Anatomia de um achado

Achado F-001 do cenário correlation — todo achado segue estas mesmas partes, sempre separadas

EVIDÊNCIA

observado

```
services.txt:4      backup-agent.service user=root  exec=/bin/bash /opt/backup/backup.sh
processes.csv:5     pid=2417 ppid=1  user=root  cmd=/bin/bash /opt/backup/backup.sh
permissions.csv:3   /opt/backup/backup.sh file root:root  0777
journal.log:6       login de aluno (publickey) a partir de 10.20.30.44
journal.log:2       backup-agent.service iniciado após o mtime do script
```

INTERPRETAÇÃO

significado técnico

O script executado como root pode ser alterado por qualquer usuário local (bit o+w). O mtime é anterior ao login do aluno: sem indício de modificação durante a sessão.

HIPÓTESE

explicação possível

Um usuário não privilegiado poderia inserir comandos que seriam executados como root na próxima execução do serviço. **Isso NÃO prova exploração.**

EVIDÊNCIA AUSENTE

o que confirmaria

Hash/conteúdo de backup.sh comparado a uma versão conhecida · autor da última modificação (auditd) — o mtime pode ser forjado com touch

CONCLUSÃO

RISCO · exploração não comprovada · confiança alta (log, permissão, processo, serviço)

Conclusões e confiança

Quatro conclusões — duas existem para não acusar

RISCO

Condição que permite abuso; exploração não comprovada

CONFIG_INADEQUADA

Configuração inadequada, sem relação de privilégio demonstrada

INCONCLUSIVO

Evidência insuficiente para concluir

CONTEXTO_OK

Relação verificada e correta — listada em “Verificações sem achado”

Confiança

nº de tipos de fonte independentes na evidência

1 baixa

2 média

≥ 3 alta

Fontes: serviço, processo, permissão, log, socket
RISCO exige ≥ 2; com uma só, é rebaixado

Nunca vira achado sozinho

serviço root

curl, bash

conexão externa

SUID em /usr/bin

Resultados nos 9 cenários

Cenário	O que a ferramenta concluiu	Conclusão
normal	Linha de base; /etc/shadow restrito verificado	CONTEXTOK
permission	report.sh 0777 sem execução privilegiada	CONFIG_INADEQUADA
privileged_service	Serviço root com script 0700 → sem achado	CONTEXTOK
correlation	Serviço root executa backup.sh 0777	RISCO
tampered_after_login	Login → mtime → início do serviço (C1+C4)	RISCO
writable_parent_dir	Script 0755 em diretório 0777 (pai gravável)	RISCO
user_to_root	bash root filho de bash do aluno, sem sudo	RISCO
ambiguous	Agente root contata destino externo	INCONCLUSIVO
missing_evidence	Permissões de /opt/x/run.sh não coletadas	INCONCLUSIVO

51

testes automatizados, todos passando

9/9

cenários com a conclusão esperada

0

RISCO nos 5 cenários sem relação de privilégio

Demonstração

Datasets — roteiro

- 1 correlation**
Caso central: 4 fontes, “Isso NÃO prova exploração”, exit=1
- 2 tampered_after_login**
Login → modificação → início do serviço
- 3 privileged_service**
Root não é o gatilho: script 0700 → sem achado, exit=0
- 4 missing_evidence · ambiguous**
Quando a ferramenta diz “não sei”
- 5 user_to_root**
Cadeia init → sshd → bash(aluno) → bash(root)



Ao vivo — VM Kali

```
$ sudo bash lab/setup_lab.sh  
$ sudo python3 -m investigator --live
```

ei-lab-backup.service
root · script 0777

RISCO

ei-lab-safe.service
root · script 0700

CONTEXTO_OK

ei-lab-id
SUID 4755 em /usr/local/bin

INCONCLUSIVO

porta 8081
http.server do kali em /tmp

INCONCLUSIVO

Plano B: --live sem sudo, mostrando as lacunas declaradas

Decisões técnicas e uso de IA



Python 3.10+, só biblioteca padrão

Nada a instalar no Kali; mesmo ecossistema do gerador



Snapshot sob demanda, sem agente

Uma execução gera um retrato do sistema



Tempo em wall-clock sem fuso

Torna comparáveis mtime, login e início (CSV × journal)



Coleta por contexto, não varredura

Só caminhos usados por serviços, processos e cron (e seus pais)



Correção no gerador do professor

random_noise() quebrava com --level intermediate/challenge



Uso de IA

- Claude (Claude Code) como apoio: arquitetura, código, testes e documentação
- Regras validadas por 51 testes sobre os 9 cenários e pelo modo live
- Uso registrado no documento técnico, seção “Uso de IA”

A ferramenta não usa LLM: coleta, normalização e correlação são regras determinísticas. Não existe etapa DADOS → LLM.

Limitações e escopo

Achados são condições, não incidentes: nenhum atribui autoria nem prova exploração.



Falsos positivos

- Escrita de grupo conta como gravável por não-root no dataset
- Root filho de não-root pode vir de mecanismo legítimo



Falsos negativos

- Cron, timers e unidades inativas ausentes do dataset
- Processos efêmeros não aparecem num snapshot único



Heurísticas

- Destino externo lido de argv
- Log ↔ atividade ligados por palavras-chave
- mtime e logs podem ser forjados ou rotacionados



Fora do escopo

- Hashes e integridade de pacotes (dpkg --verify)
- ACLs, capabilities, SELinux/AppArmor
- Containers e rootkits de kernel (confia em /proc)

Observar, correlacionar, explicar — e dizer quando não há evidência suficiente

Perguntas?

Gabriel Galazzi · João Pedro Sardou

```
$ python3 -m investigator --dataset training/correlation --out reports/correlation
```